

Warsaw, August 20, 2024

Decision

DKN.5131.1.2024

Based on Article 104 § 1 of the Act of June 14, 1960, the Code of Administrative Procedure (Journal of Laws of 2024, item 572), Article 7 sections 1 and 2, as well as Articles 60, 101, and 103 of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781), and also Article 57 section 1 letters a) and h), Article 58 section 2 letters e) and i), Article 83 sections 1 and 2, Article 83 section 4 letter a) in connection with Article 34 sections 1, 2, and 4 of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of May 4, 2016, p. 1, OJ EU L 127 of May 23, 2018, p. 2, and OJ EU L 74 of March 4, 2021, p. 35), hereinafter referred to as Regulation 2016/679, after conducting an ex officio administrative procedure regarding the violation of personal data protection regulations by X. S.A. (...) The President of the Personal Data Protection Office, stating that X. S.A. (...) violated the provisions of Article 34 sections 1 and 2 of Regulation 2016/679, consisting of failing to notify without undue delay the individuals whose data were affected by the personal data breach,

1) imposes on X. S.A. (...) an administrative fine in the amount of 4,053,173 PLN (in words: four million fifty-three thousand one hundred seventy-three zlotys),

2) orders X. S.A. (...) to notify, within 7 days from the date of delivery of this decision, the individuals whose personal data were disclosed to an unauthorized recipient as a result of the personal data breach reported to the President of the Personal Data Protection Office on July 7, 2022, in order to provide them with the information required under Article 34 section 2 of Regulation 2016/679, namely: a) a description of the nature of the personal data breach; b) the name and contact details of the data protection officer or the designation of another contact point from which more information can be obtained; c) a description of the possible consequences of the personal data breach; d) a description of the measures taken or proposed by the controller to address the breach – including measures to mitigate its potential negative effects.

Justification

X. S.A. (...), hereinafter referred to as the "Bank" or "Controller", on July 8, 2022, reported to the President of the Personal Data Protection Office, hereinafter also referred to as the "President of UODO" or "supervisory authority", a personal data breach that occurred on June 30, 2022.

In the form "Notification of a Personal Data Breach," the Controller indicated that on July 7, 2022, it received information from Z. Sp. z o.o. (a data processor acting on behalf of the Controller) that an employee of the data processor "...incorrectly sent the Bank's clients' banking documents to another bank. The documents were ultimately returned in full to X. There is a likelihood that employees of the other bank accessed them. However, the risk of significant harm to the rights and freedoms of our clients is minimized by the obligation to maintain banking secrecy regarding all information accessed by bank employees. Therefore, we did not decide to notify our clients about this incident...".

The Controller indicated that the cause of the breach was an external unintended action. The nature of the breach was also specified – the Bank indicated that there was a breach of data confidentiality. The Controller stated that the approximate number of individuals affected by the breach is (...), and the categories of personal data that were breached include: surnames and first names, parents' names, date of birth, bank account number, residential or stay address, PESEL identification number, data concerning income and/or owned assets, mother's maiden name, series and number of the identity card, other (information regarding credit and real estate). In the content of the breach notification, the Controller specified the category of individuals affected by the breach, indicating that it includes clients.

The President of UODO conducted an explanatory procedure regarding the reported breach

(registered under reference: ...), and then on January 9, 2024, initiated an ex officio administrative procedure regarding the possibility of the Bank, as the data controller, violating the obligations arising from the provisions of Article 34 sections 1 and 2 of Regulation 2016/679.

The President of UODO, as a result of the conducted explanatory procedure regarding the reported personal data breach and the administrative procedure, established the following factual state.

I. The President of UODO, acting based on Article 52 section 1 of the Act of May 10, 2018, on the Protection of Personal Data (hereinafter referred to as the Act) and Article 34 section 4 of Regulation 2016/679, by letter dated July 12, 2022, requested the Controller to take actions aimed at: 1) promptly notifying the individuals whose data are affected about the breach of their personal data, 2) providing those individuals with recommendations regarding minimizing the potential negative effects of the breach, 3) eliminating similar...

irregularities in the future. In the content of the aforementioned communication, the President of the UODO requested the Bank to inform the supervisory authority within 30 days from the date of receiving this communication about the actions taken as indicated in its content.

II. In response to the above communication, the Bank did not notify the individuals whose data was breached, stating in a letter dated July 21, 2022, that the entity to which the documents containing personal data were mistakenly sent is, in the Bank's opinion, a trusted entity. The Administrator stated that "(...) we analyzed the report from the data processor regarding the incorrectly sent documents of the bank's client to an unauthorized recipient. In particular, we focused on assessing the entity that received the bank documentation as unauthorized. This unauthorized entity that received the client's documents was another bank with which we cooperate (...) As part of the actions taken to clarify this incident, we received without unnecessary delay the complete set of incorrectly sent bank documentation. We also have statements from employees of the other bank that they do not have copies of the incorrectly received documents and are unable to identify the individuals to whom they pertained. At the same time, these individuals confirmed that they are aware of the consequences of processing personal data without a legal basis. Therefore, considering the above explanations, I ask for a re-evaluation of the justification for notifying the affected person about this incident. It seems that the risk of negative consequences for the violation of their rights and freedoms is not significant precisely because of the recipient of the incorrectly sent documents, which is another bank, i.e., a trusted entity (...)"

III. In connection with the Administrator's position expressed in the aforementioned letter, the President of the UODO requested additional explanations. In response to the supervisory authority's request, in a letter dated August 12, 2022, the Administrator indicated that "(...) The Bank did not enter into strict agreements with another bank – the trusted entity to which the report pertains, regarding the protection of personal data, as there is no such need. Banks are bound by agreements that they enter into among themselves for the functioning of the banking system. Banks are trusted institutions and co-create a sector regulated by numerous legal provisions (...)". The President of the UODO asked the Bank to answer the question: how long has the administrator been cooperating with the improper recipient, who was recognized as a trusted recipient; how has this cooperation proceeded, particularly in terms of personal data protection. The Administrator explained in the aforementioned letter that "(...) Banks that have received a license to conduct banking activities from the Financial Supervision Authority [KNF] cooperate with each other. Consequently, the bank has been cooperating with the other bank, to which the report pertains, since the establishment of relationships related to the necessity of ensuring the functioning of the banking sector. Cooperation manifests itself in various areas, e.g., cooperation in combating banking crime or cybercrime. Both banks operate within the Polish Bank Association and jointly develop [with other members] standards for the operation of entities in the banking sector. In terms of personal data protection, representatives of both banks operate within two Groups established in the Polish Bank Association (...). The cooperation is ongoing, and meetings are regular. They concern, among other things, the implementation of GDPR in banks and the exchange of experiences. I assess the cooperation with the other bank – the trusted entity as exemplary. Furthermore, our banks respect the Principles adopted by the banks (...), including chapters such as

the Principles (...) or the Principles (...). The banks [including ours] have also adopted the Principles (...) [KNF] (...). The President of the UODO asked the Administrator to indicate whether the unauthorized recipient has developed standards regarding personal data protection. The Bank clarified in this regard that "(...) the other bank – the trusted entity, has standards and applicable regulations regarding personal data protection. Information on this topic is also available on the website of that other bank (...)."

Additionally, in the letter dated August 12, 2022, the Bank stated that: "(...) it remains in constant contact with the other bank – the trusted entity. The Bank trusts the other bank, which did not familiarize itself with the documents and fulfilled the instruction to return them to the bank. This means that the consequences of this breach will not be serious. The other bank – the trusted entity is part of the banking sector, which is one of the most regulated sectors. Among other things, with this trusted entity, we create a banking system that is subject to the supervision of the KNF. We are also subject to the Act on Cybersecurity. The KNF has not issued a warning against this bank, so we consider that this other bank meets the conditions specified by banking law or the recommendations of the KNF (including those concerning information security). In doctrine and case law, banks are treated as public trust institutions, thus as trusted entities. Banks have implemented risk management systems and internal control systems. This is in accordance with legal provisions, including the Banking Law, or the recommendations of the KNF. Additionally, based on Article 104 of the Banking Law, all bank employees are obliged to maintain banking secrecy. Furthermore, according to Article 171(5) of the Banking Law, for disclosing or using information constituting banking secrecy, contrary to the authorization specified in the law, a fine of up to 1,000,000 zlotys and imprisonment for up to 3 years may be imposed. Bank employees are aware of this obligation and the associated criminal sanctions for its violation (...)."

IV. On September 14, 2022, the Administrator was asked (via electronic mail) to provide information on what the Administrator understands by indicating in the explanations.

On August 12, 2022, it was stated: "The Bank trusts another bank that has not reviewed the documents" and whether the correspondence was returned to the administrator in an unaltered state or showed signs of being opened. The administrator explained that "(...) employees of another bank, who mistakenly received the shipment intended for X, routinely opened it, and only after opening did they realize that the contents were not intended for them, i.e., another bank. There was no other way to determine the incorrect recipient of this shipment. This means that the employees of the other bank did not familiarize themselves with the entirety of this documentation. According to information from Z. S.A., their shipments are packed in ordinary white envelopes without logos, with an attached label indicating to whom the shipment is addressed – the bank, the client's surname, and the contents of the shipment. A bulk shipment sent to a specific bank contains several envelopes. The bulk shipment is labeled with information about the type of documents being sent and the client's surname. Bulk shipments are packed in courier bags with a label affixed (...) immediately after determining that the shipment was not intended for another bank, that other bank notified Z. of this fact, and sent the secured shipment to our bank. At the same time, the employees who had access to the shipment signed statements that they do not possess copies of these documents and cannot identify the individuals whose data was contained in those documents. They also stated that they are aware of the consequences of processing personal data without legal grounds (...)."

The supervisory authority assessed the evidence in terms of its credibility and evidential value. The President of the Personal Data Protection Office (UODO) deemed the evidence presented by the Administrator to be credible. This is supported by the fact that the explanations provided by the Bank are logical, coherent, and correlate with the entirety of the evidence, as well as being confirmed by a series of documents provided by the Administrator.

In this factual state, after reviewing all the evidence gathered in the case, the President of the Personal Data Protection Office considered the following: According to Article 34(1) of Regulation 2016/679, if a personal data breach may result in a high risk of adversely affecting the rights or freedoms of natural persons, the administrator shall without undue delay notify the data subject of such a breach. Article

34(2) of Regulation 2016/679 states that the notification referred to in paragraph 1 of this article shall describe in clear and plain language the nature of the personal data breach and shall contain at least the information and measures referred to in Article 33(3)(b), (c), and (d) of Regulation 2016/679. Consequently, the notification should include: - the name and contact details of the data protection officer or other contact point from which more information can be obtained; - a description of the possible consequences of the personal data breach; - a description of the measures taken or proposed by the administrator to address the personal data breach, including, where appropriate, measures to mitigate its possible adverse effects.

As a result of the analysis conducted regarding the personal data breach reported by the Administrator, which took into account the nature of the breach, its duration, the categories of data, the number of individuals affected by the breach, and the remedial measures taken – the President of the UODO concluded that the breach of confidentiality of data, particularly data concerning the surname and first name, residential or stay address, PESEL identification number, and series and number of the identity card, poses a high risk of adversely affecting the rights or freedoms of natural persons, and therefore it is necessary to notify the individuals whose data are concerned about the breach of their personal data and to provide them with all the information specified in Article 34(2) of Regulation 2016/679.

It should be emphasized that in a situation where a personal data breach results in a high risk of adversely affecting the rights or freedoms of natural persons, the administrator is obliged, under Article 34(1) of Regulation 2016/679, to notify the individuals concerned of such a breach without undue delay. This means that the administrator is required to implement all appropriate technical and organizational measures to immediately identify the personal data breach and quickly inform the supervisory authority, and in cases of high risk to the rights or freedoms, also the individuals whose data are concerned. The administrator should fulfill this obligation as soon as possible. Recital 86 of Regulation 2016/679 explains: “The administrator should without undue delay inform the data subject of a personal data breach if it is likely to result in a high risk of adversely affecting the rights or freedoms of that person, in order to enable that person to take the necessary protective measures. Such information should include a description of the nature of the personal data breach and recommendations for the data subject on minimizing potential adverse effects. Information should be communicated to the data subjects as soon as reasonably feasible, in close cooperation with the supervisory authority, respecting the guidance provided by that authority or other relevant bodies, such as law enforcement authorities. For example, the need to minimize the immediate risk of harm will require prompt notification of the data subjects, while the implementation of appropriate measures against similar or related personal data breaches may justify a later notification.”

By notifying the data subjects without undue delay, the administrator enables individuals to take necessary preventive actions to protect their rights or freedoms from the negative effects of the breach. Article...

34 paragraphs 1 and 2 of Regulation 2016/679 aim not only to ensure the most effective protection of the fundamental rights or freedoms of data subjects but also to implement the principle of transparency, which arises from Article 5 paragraph 1 letter a) of Regulation 2016/679 (see Chomiczewski Witold [in:] GDPR. General Data Protection Regulation. Commentary, ed. E. Bielak-Jomaa, D. Lubasz, Warsaw 2018). Proper fulfillment of the obligation specified in Article 34 of Regulation 2016/679 is intended to provide individuals whose data is concerned with prompt and transparent information about the breach of their personal data protection, along with a description of the possible consequences of the breach of personal data protection and the measures they can take to minimize its potential negative effects. Acting in accordance with the law and demonstrating care for the interests of the data subjects, the administrator should have provided these individuals with the best possible protection of personal data without unnecessary delay. To achieve this goal, it is essential at least to indicate the information listed in Article 34 paragraph 2 of Regulation 2016/679, which the Administrator failed to fulfill.

As indicated in the content of the submitted notification of a personal data breach, the Bank did not

notify the individuals affected by this breach, arguing that it considered the inappropriate recipient to be a trusted entity. The President of the UODO did not share this argument presented by the Administrator as guaranteeing the protection of the rights or freedoms to which the data subjects are entitled, and therefore, on July 12, 2022, he requested the Bank to take appropriate actions aimed, among other things, at promptly and correctly notifying the individuals whose data is concerned about the breach of their personal data. Despite the President of the UODO's request in this regard, the Administrator did not take appropriate action, maintaining its position. A detailed description of the Bank's position was presented in the factual description.

In the opinion of the supervisory authority, the Administrator's arguments do not deserve consideration. The collected evidence indicates that as a result of the erroneous transmission of documents containing a number of personal data, the data was disclosed to a third party, which is another bank. As previously indicated, according to Article 34 paragraph 1 of Regulation 2016/679, if a breach of personal data protection may result in a high risk of violating the rights or freedoms of natural persons, the administrator shall notify the data subject of such a breach without undue delay. Therefore, it should first be noted that the most important aspect is to analyze the likelihood of negative consequences for the individuals affected by the breach and how serious these consequences may be, taking into account the scope of the personal data (as indicated in the content of the notification of the personal data breach). Indeed, the bank that received the data package is a third party, and whether it can be treated as a trusted recipient in accordance with the Guidelines of the European Data Protection Board (EDPB) No. 9/2022[1] adopted on March 28, 2023, hereinafter referred to as Guidelines 9/2022, should be assessed considering all circumstances of the particular case. There are no grounds to assume that whenever there is an erroneous disclosure of data to a bank, it can be considered a trusted entity within the meaning of the aforementioned guidelines.

In the notification form regarding the personal data breach – as "measures taken or proposed to remedy the breach and minimize the negative effects for the individuals whose data is concerned" (point 9C of the form) – it was indicated that "(...) the Bank ultimately received a complete set of documents from its clients. Bank employees are obliged to keep all information related to the banking activities they perform confidential. They may not use it for purposes other than professional ones (...)". The Administrator, conducting an analysis of the consequences of the breach, reduced the risk of violating the rights or freedoms of individuals whose personal data was disclosed to another bank. The mitigation of this risk was argued by the Administrator based on the fact that statements were obtained from employees of another organization that they do not possess copies of the incorrectly received documents, are unable to identify the individuals to whom they pertain, and are aware of the consequences of processing personal data without legal grounds (see point II of the factual justification). Despite the President of the UODO's request to the Bank, the Administrator did not conduct a re-analysis of the risk of violating the rights or freedoms of the individuals whose data was breached and did not change its position.

In the opinion of the supervisory authority, declarations related to maintaining banking secrecy do not exempt the Administrator from the obligation to notify the individuals whose data has been breached. It should be emphasized that such statements do not guarantee that – following a change of intent – the data has not been or will not be used in the future. The insufficiency of guarantees provided by such statements and commitments of employees regarding the confidentiality of personal data is confirmed by numerous cases of breaches of employee duties (even in situations where specific breaches are associated with criminal liability). It is worth referring here to Guidelines 01/2021[2], specifically to example No. 8, which relates to "Exfiltration of business data by a former employee." In the discussed example, it describes a situation where, during the notice period, an employee of the enterprise copies business data from the enterprise's database, to which they have access rights and must fulfill their obligations. Several months later, after resigning from work, they use the data obtained in this way (mainly basic contact information) to contact clients.

businesses in order to attract them to a new company. Although the sole purpose of the former employee, who maliciously copied the data, may be limited to obtaining the contact details of the

company's clients for their own commercial purposes, the administrator does not have the authority to determine that the risk to the individuals whose data is concerned is low, as the administrator has no guarantee regarding the employee's intentions. Thus, while the consequences of the breach may be limited to exposing the individuals whose data is concerned to unwanted marketing from the former employee, it cannot be ruled out that a different, more serious breach of that data may occur. A similar factual situation (an employee of ZUS during employment, who accessed the data of insured persons; had access to it, but did not have the authority to review it) has already been the subject of consideration by the District Court in Elbląg, which in its judgment of March 24, 2021, in case file IV Pa 10/21 indicated that "(...) The behavior of the plaintiff, consisting of obtaining unlawful access to the personal data of ZUS clients, unrelated to the performed employment duties, was a deliberate and conscious action and as such fulfilled the criteria for a serious violation of fundamental employment obligations. It should be emphasized that the plaintiff was trained by the employer to perform her duties, repeatedly submitted written statements confirming her knowledge of documents related to the processing of personal data and information security at ZUS, participated multiple times in training on compliance with personal data protection regulations, possessed knowledge of the consequences of conscious violations of personal data protection, and nevertheless, through her behavior, violated not only internal regulations such as and , but also Article 4 point 12 of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 04.05.2016, p. 1; (...))."

In relation to the aforementioned case, inferring from the justification of the above judgment, it should be stated that the lack of trust must be evidenced by the mere fact of logging into the system in the absence of authorization. In the case covered by the aforementioned judgment, the lack of trust occurred despite the fact that the parties were bound by an obligation relationship. However, relating the above to the case subject to resolution in this decision, it should be noted that even more so, the lack of trust must be present in a situation where an unauthorized person gains access to personal data and moreover – is not bound to the Administrator by any obligation relationship. It should be emphasized that the Bank has no means to verify the statements of employees of another bank (as mentioned in point II of the factual justification). In fact, the Administrator does not possess any instruments that would enable him to verify such statements.

The validity of the aforementioned position is confirmed by the judgment of the Provincial Administrative Court of January 21, 2022 (case file II SA/Wa 1353/21), in which it was indicated that "(...) The assessment of the President of UODO that the Company's request, also through the Contractor, to a third party - an unauthorized recipient - for the permanent deletion of the received correspondence, and even the submission by that person of a statement regarding its permanent deletion, did not affect the assessment of the risk of personal data breach, was accurate and in line with the content of Article 80 of the Administrative Procedure Code. The President of UODO's assessment was rational, as there is no certainty that before these actions, that person did not make, for example, a photocopy or did not record the personal data contained in the document in another way, e.g. by writing it down. The mere execution of the actions indicated in the statements made by the third party - an unauthorized recipient - does not guarantee that the intentions of such a person will not change now or in the future, and the potential consequences of using such categories of data may be significant for the individuals whose data has been breached (...) the President of UODO correctly indicates that the Company has no means to verify it, although the third party faces criminal sanctions and those resulting from the personal data protection act (...)"

In summary: the fact that legal regulations, including obligations related to maintaining confidentiality (such as, for example: authorization to process personal data on behalf of the Bank, statements confirming familiarity with the applicable data processing policy at the Bank and security and confidentiality standards), do not guarantee the person whose data is concerned one hundred percent certainty and protection against the materialization of negative consequences, as the key factor is the relationships in which the entities remain.

To recognize that in a specific situation we are dealing with unauthorized disclosure of personal data to a trusted entity, such circumstances must occur in which the data administrator will have a permanent relationship with the recipient and may know their procedures, history, and other relevant details, thanks to which the recipient can be considered "trusted." From the gathered evidence, it follows that the employees of another bank reviewed the package of documents, but it does not follow that the administrator and the third party had any agreements or developed procedures for the given circumstance, which would be crucial to actually minimize the risk of consequences related to the breach of personal data protection and to be able to assume that the unauthorized recipient is a trusted recipient. A thorough analysis of Guidelines 9/2022 unequivocally... indicates that it is not the status of the recipient, recognizing them as a so-called institution (person) of public trust, nor acting within the framework of applicable legal provisions, but rather the existence of a direct (permanent) relationship between the sender and the recipient of the mistakenly sent correspondence that determines the admissibility of recognizing a specific entity as a so-called "trusted recipient." The cited guidelines emphasize the durability of the relationship between the administrator (the sender of the mistakenly sent correspondence) and the recipient (of that correspondence) and – resulting from this long-term relationship – the administrator's knowledge of the procedures, history, and other relevant details concerning the recipient, allowing the administrator to reasonably expect that the unauthorized recipient will not attempt to read or gain access to the mistakenly sent correspondence containing personal data, and if access to the mistakenly sent personal data does occur, that this recipient will not take any further action and will promptly return the personal data to the administrator (pp. 25 – 26 of Guidelines 9/2022). Thus, the recognition of a specific entity as a "trusted recipient" within the meaning of Guidelines 9/2022 is conditioned by the administrator's knowledge (in this case, the sender of the mistakenly delivered correspondence containing personal data) regarding the existence of actual personal data protection procedures (e.g., data processing security policies) applicable to the unauthorized recipient (in this case, the recipient of the mistakenly delivered correspondence containing personal data) which provide – for example – a procedure for handling such cases, including the principles for securing mistakenly received documents containing personal data until they are returned to the sender.

Taking an opposing position, i.e., the position presented by the Administrator, is therefore not justified by the content of the aforementioned guidelines; moreover, it would consequently lead to the acceptance of a certain type of automatism – since in every case where the unauthorized recipient is an entity operating within the law, it would have to be recognized as a trusted recipient. However, such an approach could lead to unjustified deviations from the obligation to notify the person whose data is concerned about a breach of the protection of their personal data in situations where there is a high risk of infringement of their rights or freedoms. For this reason, it should be acknowledged that EROD in the aforementioned guidelines did not accept that the circumstance of an unauthorized recipient acting within the law qualifies them as a trusted recipient, but rather requires maintaining a permanent relationship with such a recipient, thereby ensuring that the administrator is familiar with the applicable procedures, history, and other relevant details concerning that recipient.

The assumption of the Administrator that banks are treated as institutions of public trust, and therefore as trusted entities, is also not worthy of consideration; consequently, it is redundant to conclude that since a bank is an institution of public trust, it will, in principle, also be a trusted recipient. Referring to the argument of a trusted recipient should be supported by a thoroughly documented analysis; the consequences of data protection breaches should be examined, and it should be borne in mind that breaches with similar characteristics may have different effects on the individuals concerned, depending on various factors. The analysis conducted by the administrator must therefore be as detailed as possible and take into account the potential development of the breach, especially considering the fact that the Administrator is uncertain how many third parties had access to the mistakenly sent data package.

In the opinion of the President of UODO, merely indicating that the unauthorized recipient holds a license to conduct banking activities from the Financial Supervision Authority and that both banks

operate within the framework of the Polish Bank Association is insufficient, as the Administrator has still not demonstrated the components of an analysis in which they would consider the issue of a trusted recipient in the risk assessment conducted following the breach of personal data protection, nor have they demonstrated circumstances allowing for the recognition of another bank as a trusted recipient, in accordance with Guidelines 9/2022. Furthermore, the Administrator itself indicates that in "(...) the area of personal data protection, representatives of both banks operate within two groups established in the Polish Bank Association (...). The cooperation is ongoing, and meetings are regular. They concern, among other things, the implementation of GDPR in banks and the exchange of experiences. I assess the cooperation with another bank - a trusted entity as exemplary (...)". However, these explanations do not indicate that the entities cooperate with each other regarding data protection breaches and the procedures developed in this regard.

Additionally, it should be noted that the fact that the Administrator recognizes another bank as a trusted entity (which – as already justified above – has no legal basis) does not change the fact that there has been unauthorized processing of personal data. The fact that another bank meets certain requirements set forth in legal acts defining its obligations towards clients (data subjects) does not mean that there has been no breach of personal data protection. The Administrator does not possess any instruments in relation to another bank that would enable them to enforce the implementation of measures to mitigate the risk of infringement of the rights or freedoms of individuals whose personal data has been breached. In fact, the Administrator is forced to accept the statements of another bank without any possibility of verifying them. Enforcing the responsibility of another bank (and its employees) would only be possible after detecting the effects of the breach of personal data protection. The bank in its explanations seems to overlook the fact that Regulation 2016/679 introduced an approach in which risk management is the foundation of actions related to personal data protection and is a continuous process. The Administrator, undertaking the decision to refrain from fulfilling its obligation arising from Article 34(1) and (2) of Regulation 2016/679 should be based on a risk analysis of the violation of the rights or freedoms of the individuals whose data has been breached, and not on an analysis of the consequences of legal violations by employees of another bank, the assessment of which would only be possible after the materialization of the risk of violation of the rights or freedoms of those individuals whose data has been breached. In other words, the discussed action of the Bank practically means that the implementation of measures aimed at minimizing potential negative effects of the breach could only occur after the individuals concerned became aware of the actual consequences of this breach, such as, for example, incurring a financial obligation as a result of identity theft (more on the effects of personal data protection breaches for individuals in the further part of the decision). In fact, the individuals whose data was breached were deprived of any means to remedy the effects of the breach, to the extent that in the event of the materialization of its effects, they were deprived of the possibility of seeking accountability from the Administrator, e.g., in civil proceedings.

In the opinion of the President of the UODO, the action of the Bank should be assessed very negatively. In the context of this case, the attitude of the Administrator towards the individuals whose data it processes has been highlighted. The lack of the expected response from the Bank to subsequent letters from the supervisory authority, including the failure to comply with the request from the President of the UODO dated July 12, 2022, leads to the assumption that the adopted practice of not informing individuals whose data has been breached—justified in the manner discussed in the case of the data protection breach—is a manifestation of a systemic attitude (policy) of the Bank, namely: firstly, the Administrator a priori considers another bank as a trusted entity (even though it is unable to demonstrate this), and secondly, it does not intend to change its position (even though the supervisory authority, in its correspondence directed to the Administrator, indicates that its position is not justified under the provisions of Regulation 2016/679). In the opinion of the supervisory authority, the action of the Bank is an exemplification of the disregard for the rights of individuals whose personal data the Administrator processes, and not only those covered by the specific data protection breach.

Notifying individuals whose data has been breached should not constitute an excessive effort for an

institution such as a bank, and it would be an effective tool that would allow minimizing the risk of negative consequences of the breach for individuals. As indicated in Guidelines 9/2022, a breach of personal data protection can potentially lead to a range of negative consequences for individuals whose data is the subject of the breach. Among the possible consequences of a breach, the EROD lists: physical harm, material or non-material damages. Examples of such damages include, among others: discrimination, identity theft or identity fraud, financial losses, damage to reputation, violation of the confidentiality of personal data, and significant economic or social harm. In this case, there is no doubt that due to the scope of the data covered by the specific breach of personal data protection (including the PESEL identification number along with the first and last name), there is a high probability of the occurrence of the aforementioned damages, which means that the aforementioned breach of personal data protection is associated with a high risk of violation of the rights or freedoms of individuals. It is also indisputable that the scope of personal data that was subject to the breach allows for the unambiguous identification of the individuals to whom this data pertains.

First and foremost, it should be emphasized that the breach of personal data protection involved the PESEL identification number, which is an eleven-digit numerical symbol that uniquely identifies an individual, containing, among other things: date of birth and gender designation, and thus is closely related to the private sphere of the individual and is also subject to, as a national identification number, exceptional protection under Article 87 of Regulation 2016/679—being data of a special nature and requiring such special protection. The PESEL number serves as identifying data for each individual and is commonly used in dealings with various institutions and in legal transactions. The PESEL number, along with the first and last name, uniquely identifies an individual in a way that allows attributing negative consequences of the breach (e.g., identity theft, loan fraud) to that specific individual. Such a combination of data can be sufficient for "impersonating" the subject of that data and incurring obligations (e.g., financial obligations) in the name and to the detriment of that subject (see: <https://www.bik.pl/poradnik-bik/wyludzenie-kredytu-tak-dzialaja-oszusci> - where a case is described in which: "Only the first name, last name, and PESEL number were enough for the fraudsters to defraud several loans totaling tens of thousands of zlotys. Nothing else matched: neither the ID number nor the address of residence"). It is also impossible to overlook that the analyzed breach of personal data protection also involved the address of residence or stay and the series and number of the ID card. In assessing the risk, the type and sensitivity of the personal data disclosed as a result of the breach of personal data protection is a key factor. The Guidelines 9/2022 emphasize that a collection of various personal data is usually more sensitive than individual data.

It is worth citing one of the examples found in the Guidelines of the European Data Protection Board 01/2021 (case no. 14, p. 31), referring to the situation of "accidentally sending highly confidential personal data by mail." In the case described in the aforementioned guidelines, there was a disclosure of the social security number, which is...

the equivalent of the PESEL number used in Poland. In this case, the EROD had no doubts that the disclosed data regarding: first name and surname, email address, postal address, social security number, indicated a high risk of infringement of the rights or freedoms of individuals ("the involvement of their [the affected individuals] social security number, as well as other, more basic personal data, further increases the risk that can be described as high"). The EROD recognizes the importance of national identification numbers (in this case, the PESEL number), while emphasizing that this type of personal data breach, therefore encompassing data in the form of: first name and surname, email address, postal address, and social security number, requires the implementation of actions, i.e.: notifying the supervisory authority and informing the affected individuals about the breach.

The European Data Protection Board has no doubt that an individually assigned number that uniquely identifies a natural person should be subject to special protection, and its disclosure to unauthorized entities may involve a high risk of infringement of the rights or freedoms of individuals.

The fact that data that uniquely identifies a natural person may cause a high risk of infringement of rights or freedoms is also pointed out by the EROD in other examples provided in Guidelines 01/2021. In points 65 and 66 of Guidelines 01/2021, it is stated: "(...) The breached data allow for the

unambiguous identification of the individuals to whom the data pertains and contain other information about them (including gender, date and place of birth); moreover, they may be used by an attacker to guess customers' passwords or to conduct a spear phishing campaign targeting bank customers. For these reasons, it was deemed that the data breach is likely to result in a high risk of infringement of the rights and freedoms of all individuals whose data is concerned. Consequently, there may be material damages (e.g., financial losses) and non-material damages (e.g., identity theft or fraud)."

Similar doubts (that the disclosure of the PESEL number along with other personal data may cause a high risk of infringement of the rights or freedoms of individuals) were also held by the Provincial Administrative Court in Warsaw, which in its judgment of September 22, 2021, case file II SA/Wa 791/21, stated that "There is no doubt that the examples of damages cited in the guidelines may occur in the case of individuals whose personal data – in some cases including the PESEL identification number or series and number of the identity card – have been recorded on the disclosed recordings. The possibility of identifying individuals whose data has been breached based on the disclosed data is significant for such an assessment." Furthermore, the Court in the cited ruling indicated that "The data was disclosed to unauthorized persons, which means that a security breach occurred leading to the unauthorized disclosure of personal data, and the scope of this data, which in some cases also includes the PESEL identification number or the series and number of the identity card, determines that there is a high risk of infringement of the rights or freedoms of individuals."

Considering the above issues, it is also worth mentioning the position of the Provincial Administrative Court in Warsaw expressed in the judgment of July 1, 2022, in case file II SA/Wa 4143/21. In the justification of this judgment, the Court stated that: "It should be agreed with the President of the UODO that the loss of confidentiality of the PESEL number in conjunction with personal data such as: first name and surname, registered address, bank account numbers, and the identification number assigned to Bank customers - CIF number, is associated with a high risk of infringement of the rights or freedoms of individuals. In the case of a breach of such data as first name, surname, and PESEL number, identity theft or forgery is possible, resulting in negative consequences for the individuals whose data is concerned. Therefore, the Bank in this matter should have promptly, in accordance with Article 34(1) of the GDPR, notified the individuals whose data is concerned about the breach of personal data protection, so as to enable them to take necessary preventive actions" (emphasis added).

It should also be noted the judgment of August 31, 2022, case file II SA/Wa 2993/21, in which the WSA in Warsaw emphasized that "(...) the authority rightly assumed that there was a high risk of infringement of the rights and freedoms of individuals affected by the breach due to the possibility of easy identification of individuals whose data was breached based on the disclosed data. This data includes first name and surname, correspondence address, phone number, and PESEL number of individuals holding Polish citizenship. In this situation, the administrator was obliged to notify without undue delay the individuals whose data is concerned about the breach." The WSA in Warsaw expressed similar views in judgments of November 15, 2022, case file II SA/Wa 546/22, June 21, 2023, case file II SA/Wa 150/23, and November 6, 2023, case file II SA/Wa 996/23.

In light of the above, it is also worth recalling the judgment of the NSA of December 6, 2023, case file III OSK 2931/21: "The President of the UODO correctly established that there was a disclosure of data, including first names and surnames, as well as PESEL numbers of individuals, and thus relatively permanent, unchanging data, the disclosure of which may always pose a risk of negative consequences for the aforementioned individuals. Similarly, residential addresses are personal data, the unauthorized disclosure of which creates a probability of a high risk of negative legal consequences regardless of the fact that the disclosure of addresses occurred several years after their update."

From the infoDOK report[3] (which is being prepared...

**In the context of conducting the social Information Campaign of the RESTRICTED DOCUMENTS System, organized by the Polish Bank Association and certain banks, under the patronage of the Ministry of Internal Affairs and Administration and in cooperation, among others, with the Police and

the Consumers' Federation, it follows that in the fourth quarter of 2023, there were 2,739 attempts to defraud loans and credits, amounting to 88.3 million PLN. Over the last twelve months, the total amount of thwarted attempts to defraud loans has reached 296.1 million PLN. Furthermore, it should be noted that in the fourth quarter of 2022, there were 2,269 attempts to defraud loans and credits, amounting to 40.2 million PLN. This indicates a significant increase in attempts to defraud loans and credits during the presented period.**

Additionally, as indicated by judicial rulings, judgments in cases of loan fraud are not uncommon and have been issued by Polish courts in similar cases for a long time. For example, one can refer to the judgment of the District Court in Łęczyca from July 27, 2016 (case file I C 566/15), in which fraudsters taking a loan using someone else's data used a PESEL number, a fictitious address, and an incorrect identification number (invalid). In the justification of the aforementioned judgment, the Court stated: "The conducted evidentiary proceedings and the analysis of documents submitted by the plaintiff lead to the conclusion that it can be unequivocally stated that in the case under consideration, the defendant was not a party to the loan agreement concluded on May 5, 2014. Although the PESEL number of the defendant J. R. was used in its conclusion, the indicated place of residence does not correspond to the residence of the defendant. The defendant J. R. has never lived in W. The loan amount was transferred to an account that was not owned by the defendant. At the time of the conclusion of the loan agreement, identification document no. (...) had expired on March 15, 2014. The mobile phone number indicated in the loan agreement and its attachments does not match the actual phone numbers used by the defendant."

In another case (I C 693/16), the District Court in Zgierz ruled on November 4, 2016: "The personal data of the defendant in the form of his first name, surname, and PESEL number, which were consistent with the defendant's data, did not indicate that the defendant submitted a declaration of will to conclude a loan agreement on December 17, 2014. It is not excluded that a person who unlawfully gained access to the personal data of the defendant concluded a loan agreement on his behalf with the company (...) sp. z o.o. S.K.A. based in W. In this case, the defendant demonstrated that he had never lived at the address indicated in the loan agreement and that the phone number and email address used to register on the website and submit the loan application belonged to him."

There are still many cases related to loan fraud, where unknown individuals typically possess only the first name and surname and the correct PESEL number (the remaining data is false), which is confirmed by the judgments issued by the courts in these matters. Below are a few examples:

- **Judgment of the District Court for Łódź-Widzew in Łódź from August 13, 2020, in case file II C 1145/19, in which an unknown third party unlawfully obtained the defendant's PESEL number and identification number, while the remaining address data indicated in the loan agreement was false - "In the Court's opinion, the evidence offered by the defendant - especially the documents from the criminal case pending before the District Court in Tarnowskie Góry under case file VI K 383/16 - indicates that the loan agreement of November 8, 2014, was concluded by a third party using some personal data of Z. A. They provided a false address of residence, under which the defendant never lived, and the loan amount was transferred to a bank account that did not belong to Z. A. [...] and the identification number provided in this agreement was a number that the defendant no longer used at the time of the conclusion of the loan agreement, as this document had expired about 8 months earlier."**

- **Judgment of the District Court in Pisz from August 21, 2020, case file I C 260/20 – "[...] The Court found that when concluding the subject agreement, the defendant's data was unlawfully used and entered as the borrower's data, while it was not the defendant who was a party to the agreement. The defendant's position is confirmed by the notification he submitted regarding the commission of fraud to his detriment, as well as by the fact that the prosecutor's office is conducting proceedings in this matter against the person indicated by the defendant. It should be noted that also in the ongoing proceedings before this court regarding payment case files I C 1/19 and I C 482/19, where E. M. also appeared as the defendant, and where financial obligations were incurred in his name and surname under the same circumstances as in this proceeding, final judgments dismissing the claim were also issued. In the Court's opinion, the circumstances of concluding the agreement with the plaintiff, where the first name

and surname of the borrower and his PESEL number are identical, while there is a discrepancy regarding the remaining data resulting from the content of the defendant's identification document, i.e., the series and number of this document, the address of residence, taking into account the fact of conducting criminal proceedings against the person who allegedly impersonated the defendant for the purpose of concluding agreements remotely and incurring financial obligations in various institutions, clearly indicate that it was not the defendant who concluded the loan agreement no. (...) with the plaintiff's predecessor."**

- **Judgment of the District Court in Puławy from April 7, 2022, in case file I C 475/19, in which the Court unequivocally stated that "[...] the evidence allowing for the verification of the defendant as a party to the subject agreement is not constituted solely by the indication of his personal data: first name, surname, PESEL number, as well as the series and number of the identification document in the content of the agreement -**

in particular in a situation where the loan is concluded via an online platform, and thus it is obvious that the lender does not have the opportunity to directly verify the identity of the other party, and the agreement is not confirmed by the borrower's signature.

It should also be noted that the proper execution by the Administrator of his obligation arising from Article 34(1) of Regulation 2016/679, related, among other things, to the necessity of providing all required information within the framework of the notification of a personal data breach, in accordance with Article 34(2) in connection with Article 33(3) of Regulation 2016/679, cannot be conditional upon the occurrence of a violation of the rights or freedoms of that person as a result of the materialization of possible negative consequences of the breach (cf. judgments of the Administrative Court in Warsaw of September 22, 2021, case no. II SA/Wa 791/21, of July 1, 2022, case no. II SA/Wa 4143/21, of August 31, 2022, case no. II SA/Wa 2993/21, of November 15, 2022, case no. II SA/Wa 546/22, and of April 26, 2023, case no. II SA/Wa 1272/22).

When applying the provisions of Regulation 2016/679, one must keep in mind the purpose of this regulation (expressed in Article 1(2)), which is to protect the fundamental rights and freedoms of natural persons, in particular their right to the protection of personal data.

Moreover, the protection of natural persons in relation to the processing of personal data is one of the fundamental rights (first sentence of Recital 1 of the preamble). In the case of any doubts, e.g., regarding the performance of obligations by administrators – including in situations where there has been a breach of personal data protection – one should primarily consider these values.

It is worth emphasizing that when assessing the risk of violation of the rights or freedoms of natural persons, from which the notification of the breach concerning the data subjects is dependent, both the probability factor and the severity of potential negative consequences should be taken into account. A high level of either of these factors affects the overall assessment, from which the fulfillment of the obligations specified in Article 34(1) of Regulation 2016/679 is dependent.

Considering that due to the scope of the disclosed personal data in the analyzed case, there was a possibility of serious negative consequences materializing for the data subjects (as demonstrated above), the weight of the potential impact on the rights or freedoms of natural persons should be regarded as high. At the same time, the probability of high risk occurring as a result of the breach in question is not small and has not been eliminated.

Thus, it must be stated that in connection with the breach in question, there was a high risk of violation of the rights or freedoms of the data subjects, which consequently determines the obligation to notify the data subjects of the breach.

In Guidelines 9/2022, the EDPB indicates the factors that should be taken into account when assessing risk, referring to Recitals 75 and 76 of Regulation 2016/679, which suggest that the administrator should consider both the likelihood of occurrence and the severity of the threat to the rights or freedoms of the data subject. In the case of a personal data breach, the administrator should focus on the risk of impact on the individual arising from the breach. Therefore, when assessing the risk to the individual resulting from the personal data breach, the administrator should take into

account the specific circumstances of the breach, including the severity of the potential impact and the likelihood of its occurrence.

In this regard, when assessing risk, the EDPB recommends considering criteria such as: the type of breach, the nature, sensitivity, and amount of personal data, as well as the ease of identification, as these may affect the level of risk to natural persons. The risk of violation of the rights and freedoms of the individual, according to Guidelines 9/2022, will be greater when the consequences of the breach are more serious, as well as when the likelihood of their occurrence increases.

In summary of the above considerations, it should be stated that in the present case there is a high risk of violation of the rights or freedoms of the individuals affected by the breach, which in turn results in the Bank's obligation to notify those individuals of the breach, in accordance with Article 34(1) of Regulation 2016/679, which must include the information specified in Article 34(2) of Regulation 2016/679.

Once again, it should be emphasized that in this case, at least until the date of issuance of this administrative decision, the Bank did not provide the individuals affected by the breach with information about the personal data breach, thereby depriving them of guidance on actions they could take to effectively counter possible negative consequences of the breach.

The improper execution by the administrator of the obligation indicated in Article 34(1) and (2) of Regulation 2016/679, due to the failure to notify the data subjects of the breach of their personal data protection by not providing them without undue delay with the information specified in the aforementioned provisions of Regulation 2016/679, is therefore beyond doubt. The failure of the administrator to fulfill this obligation towards the data subjects results in the supervisory authority applying a corrective measure, as the existence of a legal violation in this regard is indisputable.

According to Article 34(4) of Regulation 2016/679, if the administrator has not yet notified the data subject of the personal data breach, the supervisory authority – taking into account the likelihood that this personal data breach poses a high risk – may require the administrator to do so or may determine that one of the conditions referred to in paragraph 3 has been met. In light of the above, the President of the UODO, acting on the basis of Article...

58 para. 2 lit. e) of Regulation 2016/679 mandated the Administrator to notify the individuals affected by the breach within the scope and within the time frame specified in the ruling of this decision.

According to Article 58 para. 2 lit. i) of Regulation 2016/679, each supervisory authority has the power to impose, in addition to or instead of other corrective measures provided for in Article 58 para. 2 lit. a) - h) and lit. j) of Regulation 2016/679, an administrative fine under Article 83 of Regulation 2016/679, depending on the circumstances of the specific case. The President of UODO states that in the case at hand, there were grounds justifying the imposition of an administrative fine on the Bank based on Article 83 para. 4 lit. a) of Regulation 2016/679, which stipulates, among other things, that a breach of the obligations of the administrator referred to in Article 34 of Regulation 2016/679 is subject to an administrative fine of up to 10,000,000 EURO, and in the case of an enterprise – up to 2% of its total annual worldwide turnover from the previous financial year, with the higher amount applying.

In accordance with the provisions of Article 83 para. 2 of Regulation 2016/679, administrative fines are imposed, depending on the circumstances of each individual case, in addition to or instead of the measures referred to in Article 58 para. 2 lit. a) - h) and lit. j) of Regulation 2016/679.

In deciding to impose an administrative fine on the Bank, the President of UODO – in accordance with the provisions of Article 83 para. 2 lit. a) - k) of Regulation 2016/679 – took into account the following circumstances of the case, which justify the necessity of applying this type of sanction in the present case and which have a burdensome effect on the amount of the imposed administrative fine:

1. The nature, gravity, and duration of the breach, taking into account the nature, scope, or purpose of the processing, the number of affected individuals whose data is concerned, and the extent of the damage suffered by them (Article 83 para. 2 lit. a) of Regulation 2016/679). In this case, a breach of Article 34 para. 1 of Regulation 2016/679 was identified (consisting of the failure to notify the

individuals concerned about the personal data breach without undue delay). This is related to an incident involving the incorrect transmission of documents by the data processor on behalf of the Administrator. As a result of the personal data breach, there was unauthorized disclosure of personal data on a wide scale, including, among other things, the PESEL number along with the first and last name and address data, as well as the series and number of the identity card, which makes it significant and serious, as this incident may lead to material or non-material damages for the individuals whose data has been breached. As indicated by the District Court in Warsaw in its judgment of August 6, 2020, case file XXV C 2596/19, the fear, and thus the loss of security, constitutes a real non-material damage associated with the obligation to remedy it. Furthermore, the Court of Justice of the EU in its judgment of December 14, 2023, in the case of Natsionalna agentsia za prihodite (C-340/21) emphasized that “Article 82 para. 1 of the GDPR should be interpreted in such a way that the fear of potential misuse of personal data by third parties, which the data subject experiences as a result of a breach of this regulation, may in itself constitute ‘non-material damage’ within the meaning of this provision.”

The President of UODO considers the long duration of the breach of the provisions of Regulation 2016/679 by the Bank as an aggravating circumstance. From the moment the Administrator became aware of the breach, i.e., from July 7, 2022, until the date of this decision, more than two years have passed. During this time, the risk of infringement of the rights or freedoms of the individuals affected by the breach could have materialized, and these individuals could not counteract it due to the Bank's failure to notify the individuals concerned about the breach.

It was established that the breach concerned the personal data of (...) individuals. Such a number of affected individuals, especially given the fact that the Bank – due to the scale and scope of its operations – processes the personal data of a very large number of clients, should be considered small, which undoubtedly works in favor of the Administrator. However, this does not affect the overall assessment of the impact of this circumstance – as an aggravating factor – on the amount of the imposed fine.

2. The intentional nature of the breach (Article 83 para. 2 lit. b of Regulation 2016/679). According to the Guidelines of the Article 29 Working Party on the application and determination of administrative fines for the purposes of Regulation No. 2016/679 (hereinafter referred to as WP Guidelines 253), confirmed by Guidelines 04/2022 on calculating administrative fines based on the GDPR (hereinafter referred to as Guidelines 04/2022), intent “includes both knowledge and purposeful action, in connection with the characteristics of the prohibited act.” The Bank made a conscious decision not to notify the individuals concerned about the breach. There is no doubt that the Bank, processing personal data on a large scale, should have knowledge in the area of personal data protection, including knowledge of the consequences of identifying a personal data breach resulting in a high risk of infringement of the rights or freedoms of individuals (and this knowledge can be required not only from the administrator but also from the data protection officer appointed by him). It should therefore be recognized that the Administrator, being aware of the responsibility resting on him, neglected his obligations related to the data breach and failed to notify the individuals concerned about this breach. Intent in the Bank's actions (that is, purposeful action with the awareness that it is contrary to the position of the President of UODO) certainly existed from the date of receipt of the request. President of the UODO addressed to him on July 12, 2022.

In this communication, the President of the UODO requested the Bank to notify about the breach of personal data protection of the individuals concerned. The supervisory authority indicated to the Bank that its previous position in this regard is inconsistent with Article 34(1) of Regulation 2016/679. Finally, the mere initiation of these proceedings by the President of the UODO regarding the obligation to notify about the breach of personal data should raise at least doubts for the Administrator regarding the correctness of the position it has adopted.

3. Actions taken by the administrator to minimize the damage suffered by the individuals concerned (Article 83(2)(c) of Regulation 2016/679). Based on the evidence collected in the case, no actions were found to have been taken by the Administrator. The Administrator's inaction in this regard prevented

the individuals concerned from taking any potential actions aimed at minimizing the negative effects of the breach of their personal data protection. The above determines the necessity to consider this criterion as aggravating for the assessment of the legitimacy and amount of the imposed administrative monetary penalty.

4. Any relevant previous violations by the administrator or processor (Article 83(2)(e) of Regulation 2016/679). When making a decision on the imposition and amount of the administrative monetary penalty, the supervisory authority is obliged to take into account any previous violations of Regulation 2016/679. Guidelines 04/2022 state: "The existence of previous violations can be considered an aggravating factor when calculating the amount of the monetary penalty. The weight attributed to this factor should be determined taking into account the nature and frequency of the previous violations. However, the absence of previous violations cannot be considered a mitigating circumstance, as compliance with the provisions of [Regulation 2016/679] is the norm" (point 94 of the guidelines).

The supervisory authority, in other administrative decisions issued, has already utilized corrective and admonitory measures against the Bank for violations of personal data protection regulations. The President of the UODO issued the following decisions:

- Decision (...), a warning for violating Article 17(1) in conjunction with Article 12(3) of Regulation 2016/679 by failing to fulfill the request for the deletion of personal data within the time specified in Article 12(3) of the aforementioned regulation;
- Decision (...), a warning for violating Article 6(1) of Regulation 2016/679 by processing personal data without a legal basis;
- Decision (...), a warning for irregularities in the process of processing personal data consisting of violating Article 6(1) of Regulation 2016/679 by processing personal data regarding the email address without a legal basis;
- Decision (...), a warning for irregularities in the process of processing personal data consisting of violating Article 6(1)(b) in conjunction with Article 5(1)(f) of Regulation 2016/679 by disclosing personal data of the complainant to an unauthorized person;
- Decision (...), an order to provide in paper form copies of all personal data processed by the Bank; an order to provide in electronic form information regarding the categories of relevant personal data and copies of personal data processed by the Bank; a warning for violating Article 12(1) and (3) and Article 15(1) and (3) of Regulation 2016/679 by failing to meet the deadline for providing copies of personal data;
- Decision (...), an order to provide in paper form copies of personal data processed by the Bank concerning transactions on the bank account and the client number; a warning for violating Article 12(1) and (3) and Article 15(3) of Regulation 2016/679;
- Decision (...), a warning for violating Article 6(1) of Regulation 2016/679; an order to delete personal data;
- Decision (...), a warning for violating Article 6(1) of Regulation 2016/679 by processing personal data without a legal basis;
- Decision (...), an order to cease processing personal data based on Article 6(1) and Article 58(2)(c) and Article 6(1)(f) and Article 58 of Regulation 2016/679 in conjunction with Article 105a(3) of the Banking Law;
- Decision (...), a warning for violating Article 6(1) of Regulation 2016/679;
- Decision (...), an order to fulfill the information obligation specified in Article 15(1) of Regulation 2016/679 by providing the requested information, in accordance with the request, and an order to deliver copies of data, in accordance with Article 15(3) of Regulation 2016/679 in connection with the request contained in the application;
- Decision (...), based on Article 6(1) of Regulation 2016/679, an order to delete personal data;
- Decision (...), based on Article 6(1) of Regulation 2016/679, an order to delete personal data;
- Decision (...), based on Article 6(1) of Regulation 2016/679, an order to delete personal data;
- Decision (...), based on Article 6(1) of Regulation 2016/679, an order to cease processing personal data contained in the loan application, processed without a legal basis;
- Decision (...), an order to provide data regarding voice recordings from conversations (Article

15(1)(c) of Regulation 2016/679);

- Decision (...), an order to deliver information about data recipients (Article 15(1)(c) of Regulation 2016/679);

- Decision (...), an order to provide data regarding voice recordings from conversations (Article 15(3) of Regulation 2016/679).

The described violations above, resulting in the supervisory authority applying corrective measures, are not insignificant for the final amount of the penalty imposed on the Administrator. The supervisory authority sees a connection between the previously identified violations and the currently analyzed violation.

provisions of Regulation 2016/679, such as the similar *modus operandi* of the Bank, which involved the deliberate failure to provide certain personal data and information to authorized entities, as occurred, for example, in the case of violations of Article 15(1) of Regulation 2016/679.

Thus, the issuance of numerous warnings to the Bank justifies not only the imposition of a financial sanction in this proceeding but also its relatively high amount.

In light of the above, it should be acknowledged that there are grounds for treating the criterion in Article 83(2)(e) of Regulation 2016/679 as aggravating.

5. The degree of cooperation with the supervisory authority to remedy the violation and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679).

In this case, the President of the Personal Data Protection Office (UODO) deemed the cooperation from the Bank to be unsatisfactory. This assessment pertains to the administrator's response to the letters from the President of UODO informing about the obligations imposed on the administrator in connection with the data protection violation. The Bank's actions revealed a lack of the expected response to the President of UODO's communication dated July 12, 2022, indicating how to remedy the violation, i.e., notifying the individuals affected by the personal data breach about the violation. It should also be noted that even the initiation of administrative proceedings regarding the obligation to notify the individuals whose data are concerned did not change the Administrator's actions in this regard. The above necessitates recognizing this criterion as aggravating from the perspective of determining the amount of the administrative fine.

6. Categories of personal data affected by the violation (Article 83(2)(g) of Regulation 2016/679).

The personal data disclosed to an unauthorized person do not belong to the special categories of personal data referred to in Article 9(1) or Article 10 of Regulation 2016/679; however, the fact that data was disclosed regarding: surnames and first names, parents' names, date of birth, bank account number, residential or stay address, PESEL identification number, data concerning earnings and/or owned assets, maiden name of the mother, series and number of the identity card, and other information (related to credit and real estate) indicates a high risk of violating the rights or freedoms of natural persons. The PESEL number, which is an eleven-digit numerical symbol that uniquely identifies a natural person, containing the date of birth, ordinal number, gender designation, and control number, is thus closely linked to the private sphere of the individual and is also subject, as a national identification number, to exceptional protection under Article 87 of Regulation 2016/679, and requires such special protection. There is no other, so specific data that would unequivocally identify a natural person. It is not without reason that the PESEL number serves as an identifying data for every individual and is commonly used in dealings with various institutions and in legal transactions. The PESEL number, along with the first and last name, uniquely identifies a natural person, allowing for the attribution of negative consequences of the violation (e.g., identity theft, loan fraud) to that specific individual.

In this context, it is worth citing the EDPB Guidelines 04/2022, which state: "Regarding the requirement to consider the categories of personal data affected by the violation (Article 83(2)(g) of Regulation 2016/679), Regulation 2016/679 clearly indicates the types of data that are subject to special protection and thus a more stringent response when imposing fines. This applies at least to the types

of data covered by Articles 9 and 10 of Regulation 2016/679 and to data not covered by the scope of these articles, the dissemination of which immediately causes harm or discomfort to the data subject (e.g., location data, private communication data, national identification numbers, or financial data such as transaction statements or credit card numbers). Generally speaking, the more categories of such data are involved in the violation or the more sensitive the data, the greater weight the supervisory authority may assign to such a factor. The quantity of data concerning each individual whose data are affected is also significant, as the scale of the violation of the right to privacy and personal data protection increases with the amount of data concerning each individual whose data are affected."

It should also be reiterated that emerging case law in this area indicates, for example, in the judgment of November 15, 2022, case reference II SA/Wa 546/22, the Administrative Court in Warsaw stated: "It was also obvious that the authority, when determining the amount of the fine, had to take into account the fact that the violation concerned data of great sensitivity (including PESEL, address, health status data)." This view was also shared by the aforementioned Court in the judgment of June 21, 2023, in case reference II SA/Wa 150/23, where the Provincial Administrative Court in Warsaw stated: "In summary, the Court holds that the disclosure of the PESEL number indicates a high risk of violating the rights or freedoms of natural persons."

In determining the amount of the administrative fine, the President of UODO found no grounds to consider mitigating circumstances that would affect the final amount of the fine. All the criteria listed in Article 83(2)(a)-(j) of Regulation 2016/679, in the opinion of the supervisory authority, are either aggravating factors or merely neutral. Also, applying the criterion mentioned in Article 83(2)(k) of Regulation 2016/679 (which requires taking into account any other aggravating or mitigating factors) does not change this assessment.

mitigating factors applicable to the circumstances of the case) no mitigating circumstances were found. Other circumstances, as indicated below, referred to in Article 83(2) of Regulation 2016/679, after assessing their impact on the established violation in this case, were deemed neutral by the President of the UODO, meaning they had neither an aggravating nor a mitigating effect on the amount of the imposed administrative monetary penalty:

1. The degree of responsibility of the controller, taking into account the technical and organizational measures implemented by them pursuant to Articles 25 and 32 (Article 83(2)(d) of Regulation 2016/679).

The violation of the provisions of Regulation 2016/679 assessed in this proceeding is not related to the technical and organizational measures applied by the controller.

2. The manner in which the supervisory authority became aware of the violation (Article 83(2)(h) of Regulation 2016/679).

The President of the UODO identified the violation of the provisions of Regulation 2016/679 as a result of a report of a personal data breach made by the Controller. By making this report, the Controller was merely fulfilling a legal obligation, and therefore there are no grounds to consider this circumstance as a mitigating factor. According to Guidelines 04/2022 "(...) when assessing this aspect, particular importance can be attributed to the question of whether the controller or processor notified of the breach on their own initiative, and if so, to what extent, before the supervisory authority was informed of the breach through – for example – a complaint or investigation. This circumstance is irrelevant when the controller is subject to specific obligations regarding breach notifications (such as the obligation to notify a personal data breach specified in Article 33). In such cases, the fact of making a notification should be considered a neutral circumstance."

3. Compliance with previously applied measures in the same case referred to in Article 58(2) of Regulation 2016/679 (Article 83(2)(i) of Regulation 2016/679).

Before issuing this decision, the President of the UODO did not apply any measures listed in Article 58(2) of Regulation 2016/679 against the Controller in the case at hand, which means that the Controller had no obligation to take any actions related to their application, and such actions, assessed by the President of the UODO, could have had an aggravating or mitigating impact on the assessment of the established violation.

4. The application of approved codes of conduct under Article 40 of Regulation 2016/679 or approved

certification mechanisms under Article 42 of Regulation 2016/679 (Article 83(2)(j) of Regulation 2016/679).

The Controller does not apply the instruments referred to in Articles 40 and 42 of Regulation 2016/679. However, their adoption, implementation, and application are not – as provided by the provisions of Regulation 2016/679 – mandatory for controllers and processors, which means that the circumstance of their non-application cannot be construed against the Controller in this case. On the other hand, the circumstance of adopting and applying such instruments as measures guaranteeing a higher than standard level of protection for processed personal data could be taken into account in favor of the Controller.

5. Financial benefits directly or indirectly achieved in connection with the violation or avoided losses (Article 83(2)(k) of Regulation 2016/679).

The President of the UODO did not find that the Controller had gained any financial benefits or avoided such losses in connection with the violation. Therefore, there are no grounds to treat this circumstance as aggravating for the Controller. The establishment of measurable financial benefits resulting from the violation of the provisions of Regulation 2016/679 should be assessed very negatively. However, the absence of such benefits for the Controller, as a natural state independent of the violation and its consequences, is a circumstance that inherently cannot be mitigating for the Controller. This is confirmed by the very wording of Article 83(2)(k) of Regulation 2016/679, which requires the supervisory authority to pay due attention to the benefits "achieved" – which occurred on the part of the entity committing the violation.

The President of the UODO does not see any other aggravating or mitigating factors applicable to the circumstances of this case.

In the opinion of the President of the UODO, the imposed administrative monetary penalty fulfills, in the established circumstances of this case, the functions referred to in Article 83(1) of Regulation 2016/679, i.e., it is effective, proportionate, and deterrent in this individual case.

Taking into account all the circumstances discussed above, the President of the UODO concluded that imposing an administrative monetary penalty on the Controller is necessary and justified by the gravity, nature, and scope of the alleged violations of the provisions of Regulation 2016/679. It should be noted that applying any other remedial measure provided for in Article 58(2) of Regulation 2016/679, especially merely issuing a reprimand (Article 58(2)(b) of Regulation 2016/679), would not be proportionate to the established irregularities in the processing of personal data and would not guarantee that the aforementioned entity would not commit similar negligence in the future, as in this case.

In accordance with the provisions of Article 103 of the Act of May 10, 2018 Act on the Protection of Personal Data (hereinafter referred to as the u.o.d.o.) the amounts expressed in euros referred to in Article 83 of Regulation 2016/679 are calculated in Polish zlotys according to the average euro exchange rate announced by the National Bank of Poland in the exchange rate table on January 28 of each year, and in the event that the National Bank of Poland does not announce the average euro exchange rate on January 28 of a given year – according to the average euro exchange rate announced in the nearest exchange rate table of the National Bank of Poland after that date.

In light of the above, the President of the Personal Data Protection Office (UODO), based on Article 83(4)(a) in conjunction with Article 103 of the u.o.d.o., imposed on the Bank – using the average euro exchange rate from January 29, 2024 (1 EUR = 4.3653 PLN) – an administrative monetary penalty in the amount of 4,053,173 PLN (which is equivalent to 928,498.06 EUR).

In the opinion of the President of UODO, the imposed monetary penalty of 4,053,173 PLN (in words: four million fifty-three thousand one hundred seventy-three zlotys) meets the criteria mentioned in Article 83(1) of Regulation 2016/679 due to the seriousness of the established violation in the context of the fundamental objective of Regulation 2016/679 – the protection of the fundamental rights and freedoms of natural persons, in particular the right to the protection of personal data.

Referring to the amount of the administrative monetary penalty imposed on the Bank, the President of

UODO considered that it is proportional to the financial situation of the Administrator and will not constitute an excessive burden for it.

The information provided by the Administrator indicates that the total annual turnover from the previous financial year in 2023 amounted to (...), which means that the amount of the administrative monetary penalty imposed in this case constitutes (...) of the aforementioned amount.

At the same time, it is worth emphasizing that the amount of the imposed penalty is only about (...) of the maximum penalty that the President of UODO could – applying in accordance with Article 83(4) of Regulation 2016/679 the maximum penalty of up to 2% of the total annual turnover from the previous financial year – impose on the Bank for the violations established in this case, i.e. (...).

The amount of the penalty was determined at such a level that, on the one hand, it constitutes an adequate response of the supervisory authority to the degree of violation of the Administrator's obligations, and on the other hand, it does not lead to a situation where the necessity to pay the financial penalty would result in negative consequences, in the form of significant job reductions or a substantial decrease in the Bank's turnover.

In the opinion of the President of UODO, the Bank should and is able to bear the consequences of its negligence in the area of data protection, as evidenced by, among other things, the "Report (...)".

Finally, it is necessary to indicate that in determining the amount of the administrative monetary penalty in this case, the President of UODO applied the methodology adopted by the European Data Protection Board (EDPB) in Guidelines 04/2022. According to the guidelines presented in this document:

1. The President of UODO categorized the violations of the provisions of Regulation 2016/679 established in this case (see Chapter 4.1 of Guidelines 04/2022). The violations established in this case of both provisions of Regulation 2016/679 (Article 34(1) and (2)) belong – in accordance with Article 83(4)(a) of Regulation 2016/679 – to the category of violations subject to a lower penalty of the two provided for in Regulation 2016/679 (with a maximum amount of up to 10,000,000 EUR or up to 2% of the total annual turnover of the enterprise from the previous financial year). They have therefore been considered in abstracto (independently of the individual circumstances of the specific case) by the EU legislator as less serious than the violations indicated in Article 83(5) of Regulation 2016/679.
2. The President of UODO assessed the violations established in this case as violations of low severity (see Chapter 4.2 of Guidelines 04/2022). In this assessment, the criteria among those listed in Article 83(2) of Regulation 2016/679 that relate to the subject matter of the violations (constituting the "seriousness" of the violation), namely: the nature, gravity, and duration of the violations (Article 83(2)(a) of Regulation 2016/679), the intentional or unintentional nature of the violations (Article 83(2)(b) of Regulation 2016/679), and the categories of personal data to which the violations pertained (Article 83(2)(g) of Regulation 2016/679) were taken into account. A detailed assessment of these circumstances has been presented above. It should be noted that considering their combined impact on the assessment of the violations established in this case treated in their entirety leads to the conclusion that the level of their seriousness is also low in concreto (on the scale of the seriousness of violations presented in point 60 of Guidelines 04/2022). Consequently, this results in the acceptance – as the starting amount for calculating the penalty – of a value falling within the range of 0 to 10% of the maximum penalty that could be imposed on the Bank.

Considering that Article 83(4) of Regulation 2016/679 obliges the President of UODO to accept as the maximum penalty for the violations indicated in this provision the amount of 10,000,000 EUR or – if this amount is higher than 10,000,000 EUR – the amount constituting 2% of the Bank's turnover from the previous financial year, the President of UODO concluded that the so-called dynamic maximum penalty amount resulting from the application of the 2% rate applied to the Bank's turnover for 2023 is applicable in this case.

Having at his disposal the range (...), the President of UODO accepted, as adequate and justified by the circumstances of the case, the starting amount for calculating the penalty to be (...) (constituting

2% of the dynamic maximum penalty amount).

3. In accordance with the guidance of the European Data Protection Board presented in point 66 of Guidelines 04/2022 (with respect to enterprises whose annual turnover... exceeds 500 million EUR) the President of the UODO did not find it justified to take advantage of the possibility of reducing the initial amount based on the assessment of the severity of the violation, which this possibility is provided for in the guidelines (in Chapter 4.3) for smaller enterprises in terms of size and economic strength. The EROD indicates that in the case of large entities (which the Bank undoubtedly is in this case, as evidenced by its revenues) "the size of the enterprise is already reflected in the dynamic statutory maximum amount" (point 66 of the Guidelines 04/2022).

4. The President of the UODO assessed the impact of the remaining circumstances (apart from those considered above in the assessment of the severity of the violation) indicated in Article 83(2) of Regulation 2016/679 (see Chapter 5 of the Guidelines 04/2022). These circumstances, which may have an aggravating or mitigating effect on the assessment of the violation, relate – as assumed by the Guidelines 04/2022 – to the subjective side of the violation, that is, to the entity itself that committed the violation and to its behavior before the violation, during it, and after its occurrence. A detailed assessment and justification of the impact of each of these premises on the assessment of the violation have been presented above. The President of the UODO concluded (as justified in the reasoning of the decision presented above) that the aggravating circumstances in this case, and thus additionally increasing the amount of the penalty imposed by this decision, are the actions taken to minimize the damage (Article 83(2)(c) of Regulation 2016/679), the previous violations identified by the President of the UODO on the part of the Bank (Article 83(2)(e) of Regulation 2016/679), as well as the degree of cooperation of the Bank with the President of the UODO in order to remedy the violation and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679). The remaining premises (from Article 83(2)(d), (h), (i), (j), (k) of Regulation 2016/679) – as indicated above – did not have any impact, either mitigating or aggravating, on the assessment of the violation and consequently on the amount of the penalty. Therefore, due to the existence of additional aggravating circumstances in the case, related to the subjective side of the violations (the assessment of the Bank's conduct before and after the violations), the President of the UODO deemed it justified to increase the amount of the penalty determined based on the assessment of the severity of the violations (point 2 above). In the opinion of the President of the UODO, the appropriate increase in the amount of the penalty in relation to the impact of these premises on the assessment of the violations is to raise it to the amount of (...) EUR.

5. The President of the UODO stated that the amount of the administrative monetary penalty determined in the manner presented above does not exceed – in accordance with Article 83(3) of Regulation 2016/679 – the legally defined maximum amount of the penalty provided for the most serious violation (see Chapter 6 of the Guidelines 04/2022).

6. Despite the fact that the amount of the penalty determined according to the above principles does not exceed the legally defined maximum, the President of the UODO found that it requires additional adjustment due to the principle of proportionality mentioned in Article 83(1) of Regulation 2016/679 as one of the three directives for penalty assessment (see Chapter 7 of the Guidelines 04/2022). Undoubtedly, a monetary penalty of (...) would be effective (due to its severity, it would achieve its repressive goal, which is to punish for unlawful behavior) and deterrent (allowing effectively discouraging both the Bank and other administrators from committing violations of the provisions of Regulation 2016/679 in the future). However, such a penalty would be – in the opinion of the President of the UODO – disproportionate both in relation to the severity of the identified violations (which is low in abstracto and in concreto – see points 1 and 2 above) and due to its excessive severity – in relation to that severity. The principle of proportionality requires, among other things, that the measures adopted by the administrative authority do not exceed what is appropriate and necessary to achieve justified goals (see points 137 and 139 of the Guidelines 04/2022). In other words: "A sanction is proportional if it does not exceed the threshold of severity determined by taking into account the circumstances of the specific case" (P. Litwiński (ed.), Regulation of the European Parliament and

Council (EU) 2016/679 of April 27, 2016 [...]; Commentary on Article 83 [in:] P. Litwiński (ed.) General Data Protection Regulation. Data Protection Act. Selected sectoral provisions. Commentary).

Taking into account the proportionality of the penalty, the President of the UODO further reduced the amount of the penalty – to the amount of (...) (equivalent to [...] PLN). In his opinion, such determination of the final amount of the imposed penalty will not affect its effectiveness and deterrent nature. This amount constitutes a threshold, above which further increases in the amount of the penalty will not be associated with an increase in its effectiveness and deterrent nature. On the other hand, a greater reduction in the amount of the penalty could occur at the expense of its effectiveness and deterrent nature, as well as a coherent understanding, application, and enforcement of Regulation 2016/679 in relation to other supervisory authorities and the EROD, and the principle of equal treatment of entities in the EU and EEA internal market.

In summary, in the opinion of the President of the UODO, the administrative monetary penalty imposed in this case on the Administrator meets, in light of the overall individual circumstances of the case, the criteria (functions of the penalty) referred to in Article 83(1) of Regulation 2016/679, due to the severity of the identified violations in the context of the fundamental requirements and principles of Regulation 2016/679.

Having this in mind, the President of the UODO decided as stated in the operative part of this decision.

[1] The aforementioned guidelines updated and supplemented the Guidelines.

Working Group Art. 29 on Reporting Personal Data Breaches in accordance with Regulation 2016/679 (Wp250 rev.01), adopted on October 3, 2017.

[2] Guidelines of the European Data Protection Board 01/2021 on examples regarding the notification of personal data breaches adopted on December 14, 2021, version 2.0 (hereinafter "Guidelines 01/2021").

[3] <https://www.zbp.pl/getmedia/2f8a1812-dca0-4242-b460-5de48b66f719/infodok-2023-10-12-wydanie-56-sklad-240126-gk05>

[4] <https://www.zbp.pl/getmedia/6fdef6c1-3d63-43f6-a992-179a333455c7/infodok422>

[5] https://edpb.europa.eu/system/files/2024-01/edpb_guidelines_042022_calculationofadministrativefines_pl

Print Article

Metadata

Provider:

Department of Control and Violations

Created by:

Mirosław Wróblewski

2024-08-20

Entered by:

Wioletta Golańska

2024-09-03 14:14:52

Last modified by:

Natalia Tołwińska

2024-09-09 10:47:14